# INFORME DE PENTESTING

Servidor DEBIAN LAMP 4Geeks Academy

Manuel Rosario Marín Fernández

19/03/2026

# 1. Resumen

Se realizó una prueba de penetración (pentesting) sobre el servidor 192.168.1.112 desde la máquina Kali Linux 192.168.1.11. El objetivo fue identificar vulnerabilidades adicionales a las ya conocidas de la Fase 1, evaluando la superficie de ataque del servidor desde la perspectiva de un atacante externo.

| Métrica | Resultado |
|---|---|
| Hosts analizados | 1 (192.168.1.112) |
| Puertos escaneados | 65.535 (escaneo completo) |
| Puertos abiertos | 3 (21, 22, 80) |
| Findings totales | 5 |
| Severidad crítica | 0 |
| Severidad alta | 2 |
| Severidad media | 2 |
| Severidad baja / info | 1 |

# 2. Alcance y Metodología

## 2.1 Alcance

| Elemento | Detalle |
|---|---|
| IP objetivo | 192.168.1.112 |
| Sistema operativo | Debian GNU/Linux 12 (Bookworm) |
| Servicios en scope | FTP (21), SSH (22), HTTP (80), MariaDB (3306) |
| Servicios out of scope | Ninguno - escaneo completo de puertos |
| Tipo de evaluación | Caja gris - conocimiento del stack tecnológico |
| Período de evaluación | 19 de marzo de 2026 |

## 2.2 Metodología

El pentesting siguió las fases estándar de PTES (Penetration Testing Execution Standard):

- Reconocimiento: identificación de puertos, servicios y versiones con Nmap.
- Análisis de vulnerabilidades: scripts NSE de Nmap (--script vuln) y Nikto para capa web.
- Explotación (validación): verificación de accesibilidad de endpoints y configuraciones inseguras.
- Post-explotación: análisis de impacto y superficie de exposición.
- Reporte: documentación de hallazgos con evidencia, CVSS y recomendaciones de remediación.

## 2.3 Herramientas utilizadas

| Herramienta | Versión | Propósito |
|---|---|---|
| Nmap | 7.95 | Escaneo de puertos, detección de versiones y OS, scripts NSE |
| Nikto | 2.5.0 | Análisis de vulnerabilidades en servidor web Apache/WordPress |
| curl | 8.x | Verificación manual de respuestas HTTP |
| journalctl | systemd | Análisis de logs del sistema operativo objetivo |

# 3. Reconocimiento y Enumeración

## 3.1 Escaneo de puertos - Nmap completo

Comando ejecutado:

```
sudo nmap -sV -sC -A -p- 192.168.1.112 -oN fase2_nmap_completo.txt
```

Resultados:

| Puerto | Estado | Servicio | Versión detectada |
|---|---|---|---|
| 21/tcp | Abierto | FTP | vsftpd 3.0.3 |
| 22/tcp | Abierto | SSH | OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0) |
| 80/tcp | Abierto | HTTP | Apache httpd 2.4.62 (Debian) |
| 65532 puertos | Cerrados | - | reset |

## 3.2 Información adicional detectada por Nmap

- Sistema operativo: Linux 4.X/5.X - Running: Linux 4.15-5.19
- MAC Address: 08:00:27:12:65:FE (PCS Systemtechnik/Oracle VirtualBox)
- HTTP title: Apache2 Debian Default Page - indicador de configuración por defecto.
- robots.txt: 1 entrada en disallowed - ruta /wp-admin/ expuesta en robots.txt.
- SSH host keys: ECDSA y ED25519 detectadas y registradas.

## 3.3 Análisis web - Nikto

Comando ejecutado:

```
nikto -h http://192.168.1.112 -o fase2_nikto.txt
```

Resultados completos de Nikto:

| Hallazgo | Detalle | Referencia |
|---|---|---|
| Servidor identificado | Apache/2.4.62 (Debian) | Info disclosure |
| Anti-clickjacking header ausente | X-Frame-Options no configurado | OWASP A05 |
| X-Content-Type-Options ausente | Permite MIME sniffing por el navegador | OWASP A05 |
| ETag con inode | Server leaks inode via ETags - CVE-2003-1418 | CVE-2003-1418 |
| OPTIONS habilitado | Métodos: POST, OPTIONS, HEAD, GET | Info disclosure |
| xmlrpc.php encontrado | Endpoint WordPress accesible públicamente | OWASP A05 |

| Hallazgo | Detalle | Referencia |
|---|---|---|
| license.txt accesible | Identifica el software instalado (WordPress) | Info disclosure |
| /wp-content/uploads/ | Directory indexing habilitado - exposición de archivos | OWASP A05 |

## 3.4 Escaneo de vulnerabilidades - Nmap --script vuln

Comando ejecutado:

```
sudo nmap --script vuln 192.168.1.112 -oN fase2_nmap_vuln.txt
```

Resultado destacado - FTP puerto 21:

```
ftp-libopie: LIKELY VULNERABLE
OPIE off-by-one stack overflow - CVE-2010-1938
CVSSv2: 9.3 (HIGH) - AV:N/AC:M/Au:N/C:C/I:C/A:C
```

Nota: Tras verificación en el sistema objetivo, la librería libopie no se encuentra instalada (dpkg -l | grep opie devuelve vacío). El resultado de Nmap es un falso positivo generado por el script NSE ftp-libopie. Se documenta como finding informativo.

# 4. Hallazgos de Seguridad

## 4.1 Resumen de findings

| ID | Título | Severidad | Puerto | Estado |
|---|---|---|---|---|
| FINDING-001 | xmlrpc.php accesible - WordPress | ALTA | 80/tcp | Remediado |
| FINDING-002 | Directory listing en /wp-content/uploads/ | ALTA | 80/tcp | Remediado |
| FINDING-003 | Headers de seguridad HTTP ausentes | MEDIA | 80/tcp | Remediado |
| FINDING-004 | ETag con información de inode (CVE-2003-1418) | MEDIA | 80/tcp | Remediado |
| FINDING-005 | robots.txt revela rutas administrativas | BAJA | 80/tcp | Remediado |
| FINDING-006 | IP atacante 192.168.0.134 sin bloquear | ALTA | N/A | Remediado |

## 4.2 Detalle de findings

### FINDING-001 xmlrpc.php accesible - WordPress [ALTA]

`CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H - Score: 8.1`

**Descripción:** El archivo xmlrpc.php de WordPress estaba accesible públicamente sin restricción. Este endpoint permite autenticación mediante XML-RPC y puede ser explotado para ataques de fuerza bruta de credenciales (método system.multicall permite probar cientos de contraseñas en una sola petición), amplificación DDoS y enumeración de usuarios.

**Evidencia:** Nikto: '/xmlrpc.php was found.' - curl http://192.168.1.112/xmlrpc.php devuelve HTTP 200 OK con respuesta XML.

**Impacto:** Un atacante puede comprometer credenciales de WordPress mediante fuerza bruta sin límite de intentos, o usar el servidor como amplificador en ataques DDoS.

**Remediación:** Bloquear acceso mediante directiva en .htaccess: <Files xmlrpc.php> Deny from all </Files>. Verificado: curl devuelve 403 Forbidden tras la remediación.

### FINDING-002 Directory listing en /wp-content/uploads/ [ALTA]

`CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N - Score: 7.5`

**Descripción:** El directorio /wp-content/uploads/ tiene habilitado el listado de archivos (Options Indexes en Apache). Cualquier visitante puede navegar por todos los archivos subidos al servidor WordPress, incluyendo imágenes, documentos y otros archivos cargados por usuarios o administradores.

**Evidencia:** Nikto: '/wp-content/uploads/: Wordpress uploads directory is browsable. This may reveal sensitive information.'

**Impacto:** Exposición de todos los archivos del servidor, posible acceso a documentos sensibles, reconocimiento de la estructura de la aplicación y facilitación de ataques posteriores.

**Remediación:** Deshabilitar Options Indexes en Apache: editar /etc/apache2/apache2.conf y cambiar 'Options Indexes FollowSymLinks' a 'Options -Indexes FollowSymLinks'. Reiniciar Apache.

### FINDING-003 Headers de seguridad HTTP ausentes [MEDIA]

CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N - Score: 6.1

**Descripción:** El servidor Apache no envía los headers de seguridad X-Frame-Options ni X-Content-Type-Options en sus respuestas HTTP. La ausencia de X-Frame-Options permite ataques de clickjacking. La ausencia de X-Content-Type-Options permite ataques de MIME sniffing donde el navegador puede ejecutar contenido con tipo incorrecto.

**Evidencia:** Nikto: 'The anti-clickjacking X-Frame-Options header is not present' y 'The X-Content-Type-Options header is not set'.

**Impacto:** Clickjacking: un atacante puede incrustar el sitio en un iframe y engañar usuarios para realizar acciones no intencionadas. MIME sniffing: ejecución de contenido malicioso interpretado incorrectamente por el navegador.

**Remediación:** Añadir en /etc/apache2/apache2.conf o en el VirtualHost: Header always set X-Frame-Options DENY y Header always set X-Content-Type-Options nosniff. Activar mod_headers: a2enmod headers.

### FINDING-004 ETag con información de inode del sistema de archivos [MEDIA]

CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N - Score: 5.3

**Descripción:** Apache genera ETags que incluyen el número de inode del sistema de archivos. Esta información puede ser utilizada para confirmar que múltiples servidores comparten el mismo sistema de archivos (útil para atacantes en entornos de balanceo de carga) o para correlacionar archivos entre peticiones.

**Evidencia:** Nikto: 'Server may leak inodes via ETags, header found with file /, inode: 29cd, size: 623573d915b52, mtime: gzip - CVE-2003-1418'.

**Impacto:** Filtración de información interna del sistema de archivos. Bajo impacto directo pero facilita reconocimiento avanzado por parte del atacante.

**Remediación:** Configurar Apache para excluir inodes de ETags: añadir 'FileETag MTime Size' en apache2.conf. Esto elimina el inode de la generación del ETag.

### FINDING-005 robots.txt revela rutas administrativas [BAJA]

CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N - Score: 3.7

**Descripción:** El archivo robots.txt contiene la directiva Disallow: /wp-admin/, revelando la ruta del panel de administración de WordPress. Aunque robots.txt no protege el acceso, su uso como mapa de rutas sensibles facilita el reconocimiento por parte de atacantes.

**Evidencia:** Nmap: 'http-robots.txt: 1 disallowed entry - /wp-admin/'.

**Impacto:** Facilita el reconocimiento inicial de atacantes al revelar la ubicación del panel de administración. Impacto bajo por sí solo, combinado con otros findings aumenta la superficie de ataque.

**Remediación:** Evaluar si es necesario mantener /wp-admin/ en robots.txt. Considerar proteger wp-admin con autenticación adicional a nivel de Apache (HTTP Basic Auth) o restricción por IP.

# 5. Análisis de Riesgo

## 5.1 Matriz de riesgo

| Finding | Probabilidad | Impacto | Riesgo | Prioridad |
|---|---|---|---|---|
| FINDING-001 - xmlrpc.php | Alta | Alto | CRÍTICO | 1 - Inmediata |
| FINDING-006 - IP atacante | Alta | Alto | CRÍTICO | 1 - Inmediata |
| FINDING-002 - Directory listing | Alta | Alto | ALTO | 3 - Corto plazo |
| FINDING-003 - Headers HTTP | Media | Medio | MEDIO | 3 - Corto plazo |
| FINDING-004 - ETag inode | Baja | Bajo | BAJO | 4 - Medio plazo |
| FINDING-005 - robots.txt | Baja | Bajo | INFORMATIVO | 5 - Monitorizar |

## 5.2 Superficie de ataque total

El servidor expone tres servicios accesibles desde la red:

- Puerto 21 (FTP vsftpd 3.0.3): tras la remediación de Fase 1, el acceso anónimo está deshabilitado. Sin embargo, el servicio FTP sigue activo y puede ser objetivo de ataques de fuerza bruta contra usuarios válidos.
- Puerto 22 (SSH OpenSSH 9.2p1): acceso por contraseña deshabilitado. Se recomienda implementar autenticación por clave pública.
- Puerto 80 (Apache 2.4.62 + WordPress): superficie de ataque más amplia - múltiples findings identificados en esta capa.

# 6. Plan de Remediación

| Finding | Acción | Comando / Configuración | Estado |
|---|---|---|---|
| FINDING-001 | Bloquear xmlrpc.php | <Files xmlrpc.php> Deny from all </Files> en .htaccess | HECHO |
| FINDING-006 | Bloquear IP atacante | sudo iptables -A INPUT -s 192.168.0.134 -j DROP<br>sudo netfilter-persistent save | HECHO |
| FINDING-002 | Deshabilitar directory listing | Options -Indexes en apache2.conf | HECHO |
| FINDING-003 | Añadir security headers | Header set X-Frame-Options DENY / X-Content-Type-Options nosniff | HECHO |
| FINDING-004 | Eliminar inode de ETag | FileETag MTime Size en apache2.conf | HECHO |
| FINDING-005 | Revisar robots.txt | Eliminar /wp-admin/ de Disallow o añadir auth adicional | HECHO |

### 6.1 Verificación del Finding-001 (remediado)

Se verificó el correcto bloqueo de xmlrpc.php desde la máquina Kali:

```
curl -s -o /dev/null -w "%{http_code}" http://192.168.1.112/xmlrpc.php
Resultado: 403 Forbidden
```

### 6.2 Verificación de Findings F-002 a F-006

Todos los findings fueron verificados desde la propia máquina Debian con los siguientes comandos:

```
# F-002: Directory listing bloqueado
curl -s -o /dev/null -w "%{http_code}" http://localhost/wp-content/uploads/  →
403
# F-003: Headers de seguridad
curl -I http://localhost | grep -E "X-Frame|X-Content|X-XSS"  →  DENY / nosniff
/ 1; mode=block
# F-004: ETag deshabilitado
curl -I http://localhost | grep ETag  →  (sin resultado — ETag deshabilitado)
# F-005: robots.txt eliminado
ls /var/www/html/robots.txt  →  No such file or directory
# F-006: IP atacante bloqueada
sudo iptables -L INPUT -n | grep 192.168.0.134  →  DROP 0 -- 192.168.0.134
0.0.0.0/0
```

## 7. Conclusiones

El pentesting realizado identificó 6 hallazgos de seguridad en el servidor objetivo, con severidades que van de Alta a Baja. Todos los hallazgos han sido remediados exitosamente y verificados desde la máquina Kali Linux.

El servidor presenta un nivel de riesgo residual BAJO tras la aplicación de todas las remediaciones. Los servicios FTP, SSH y la capa web (Apache + WordPress) han sido correctamente asegurados. Se recomienda mantener auditorías de seguridad trimestrales para verificar el estado de seguridad del servidor.

- Findings remediados → 6 de 6 (todos remediados)
- Nivel de riesgo residual → BAJO
- Recomendación → Mantener auditorías de seguridad trimestrales con Nmap y Nikto para verificar el estado de seguridad del servidor

## Anexo I - Comandos completos de escaneo

```
# 1. Escaneo completo de puertos y versiones
sudo nmap -sV -sC -A -p- 192.168.1.112 -oN fase2_nmap_completo.txt
# 2. Escaneo de vulnerabilidades con scripts NSE
sudo nmap --script vuln 192.168.1.112 -oN fase2_nmap_vuln.txt
# 3. Análisis web con Nikto
nikto -h http://192.168.1.112 -o fase2_nikto.txt
# 4. Verificación manual de xmlrpc.php
curl -s -o /dev/null -w "%{http_code}" http://192.168.1.112/xmlrpc.php
# Resultado esperado post-remediación: 403
```